

Process for Attack Simulation and Threat Analysis (PASTA) Report

Scenario Overview & Methodology

This report applies the PASTA (Process for Attack Simulation and Threat Analysis) framework to evaluate the security posture of a sneaker e-commerce application. The objective is to align business requirements with technical defenses by identifying high-value assets, such as user PII and payment data.

The following analysis was developed by decomposing the application’s data flow and modeling potential attack paths to determine the most effective security controls to mitigate risks like SQL Injection and Session Hijacking.

Stages	Sneaker company
I. Define business and security objectives	• The app must seamlessly connect sellers and shoppers, allowing them to sign up, log in, and manage accounts easily. • The system must process transactions quickly with several payment options while maintaining strict data privacy to avoid legal issues. • The primary security goal is to handle user information and direct messages responsibly to maintain buyer confidence.
II. Define the technical scope	I prioritize Public Key Infrastructure (PKI) because the application handles sensitive credit card information and user data. PKI provides the necessary RSA and AES encryption to secure the exchange of information between the app and the user, which is critical for preventing data breaches in a commerce environment.

III. Decompose application	The Product Search Process (see Figure 1) shows user queries moving to the Database, identifying it as a high-value target for data-driven attacks.
IV. Threat analysis	● Internal Threat: A standard user or employee who intentionally or accidentally alters or deletes critical product data within the SQL database. ● External Threat: A threat actor who uses social engineering against an employee to compromise the authentication system or a virus to gain unauthorized access.
V. Vulnerability analysis	● Vulnerability 1: A lack of prepared statements in the application codebase, which could allow an attacker to exploit the database via SQL injection. ● Vulnerability 2: Payment forms that fail to properly encrypt credit card information, making the system vulnerable to session hijacking.
VI. Attack modeling	The Attack Tree (see Figure 2) shows an attacker can reach User Data via two main paths: SQL Injection (lack of prepared statements) or Session Hijacking (weak credentials).
VII. Risk analysis and impact	1. Multi-Factor Authentication (MFA): To reduce risk from compromised credentials. 2. Prepared Statements: To neutralize the threat of SQL injection.

	3. TLS Encryption: To ensure data in motion is fully encrypted. 4. IP Allow-listing: To prevent unauthorized external connections to the database.
--	--

The “Evidence” (Outside The Table)

Figure 1: Data Flow Diagram

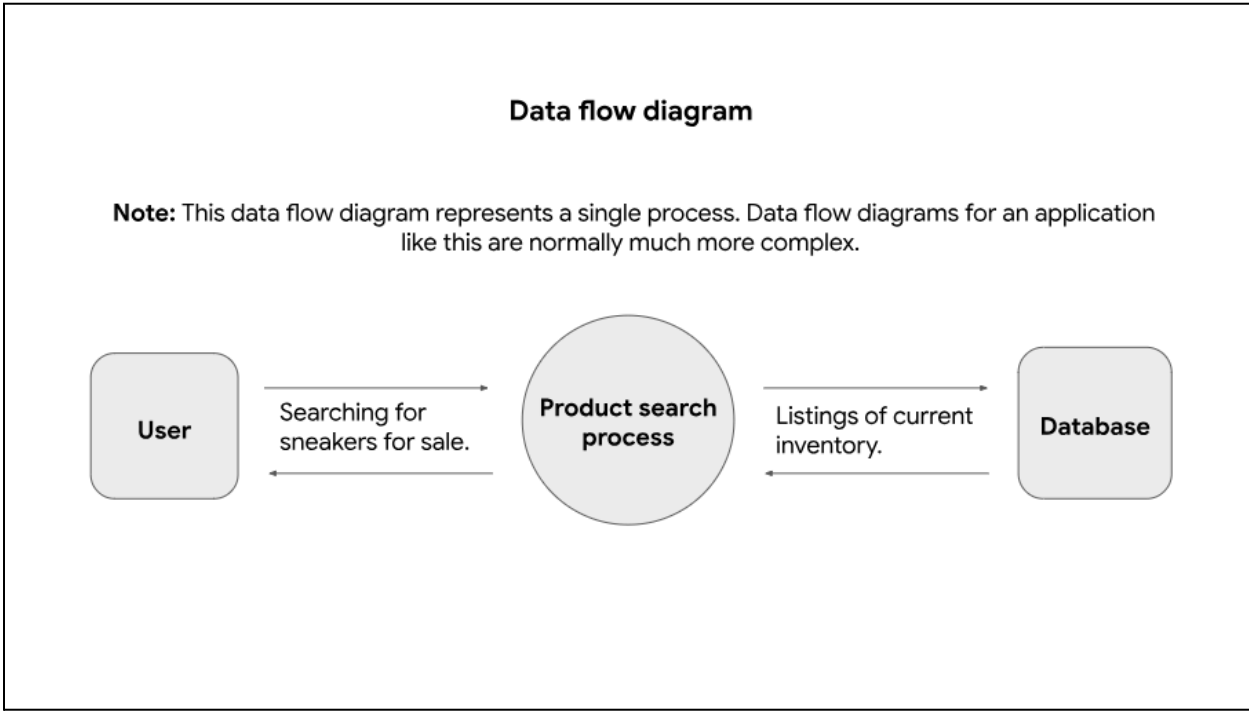
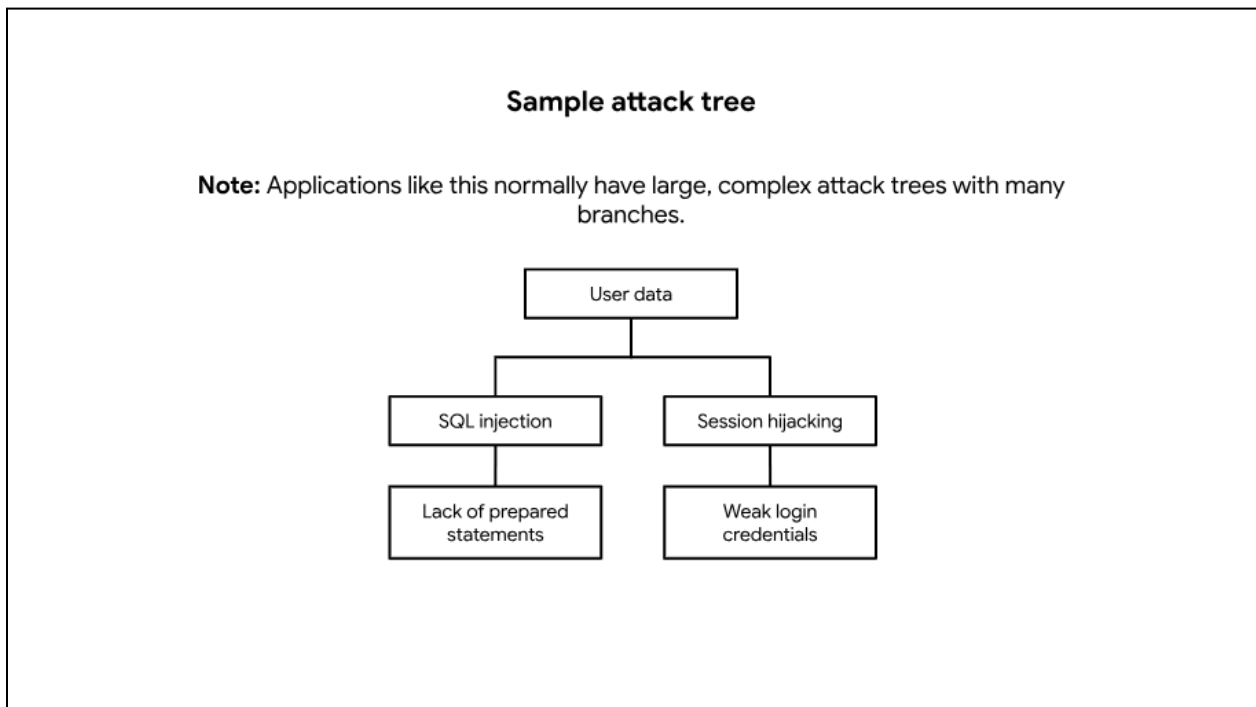


Figure 2: Attack Tree



Project Summary: Security Analysis & Remediation

Through the application of the PASTA framework, this analysis identified critical technical vulnerabilities within the sneaker application's architecture. By mapping the Product Search Process in the Data Flow Diagram (Figure 1) and modeling exploitation paths in the Attack Tree (Figure 2), it was determined that the lack of prepared statements poses a high risk of SQL Injection.

To ensure the business objectives of data privacy and user confidence are met, the immediate implementation of PKI encryption, Multi-Factor Authentication, and parameterized queries is recommended. These controls effectively reduce the attack surface and protect sensitive user PII and financial records from both internal and external threats.

